

AUDITORÍA Y REPORTE DE INCIDENTE DE SEGURIDAD

Compromiso de Sitio Web mediante Ataque de Fuerza Bruta
e Inyección de Código

Autor: Ing. Mauro Alejandro Guadarrama García

Ingeniero en Sistemas Computacionales

Proyecto de Portafolio
Certificado Profesional de Ciberseguridad de Google
Junio 2026

Sección 1: Identificación del Protocolo de Red

A partir del análisis del registro tcpdump y la recreación del entorno aislado (sandbox), se identificaron los siguientes protocolos de red involucrados en el incidente:

- **Protocolo DNS (Domain Name System):** Utilizado por el navegador para resolver el nombre de dominio inicial yummyrecipesforme.com a su dirección IP, y posteriormente para resolver el dominio malicioso greatrecipesforme.com. DNS opera típicamente sobre el protocolo UDP en la capa de transporte del modelo TCP/IP.
- **Protocolo HTTP (Hypertext Transfer Protocol) / HTTPS:** Utilizado para realizar las peticiones de descarga del contenido de las páginas web (y del archivo ejecutable malicioso). HTTP/HTTPS opera en la capa de aplicación del modelo TCP/IP.

Hallazgo clave: Los atacantes abusaron del protocolo HTTP estándar para forzar la descarga de un script, el cual manipuló las peticiones DNS subsecuentes para redirigir el tráfico hacia la infraestructura del atacante.

Sección 2: Documentación del Incidente

Resumen Ejecutivo

El sitio web yummyrecipesforme.com fue comprometido por un ex-empleado mediante un ataque de fuerza bruta dirigido al panel de administración. Tras obtener acceso, el atacante inyectó código JavaScript malicioso en el sitio principal. Este código obligaba a los visitantes a descargar un archivo ejecutable bajo el pretexto de una actualización del navegador. Al ejecutarse, el archivo redirigía el tráfico de los usuarios hacia el dominio falso greatrecipesforme.com e instalaba malware que degradaba el rendimiento de los equipos de los clientes.

Línea de Tiempo y Pruebas

- **Vulnerabilidad Inicial:** El atacante aprovechó la falta de controles de seguridad en el inicio de sesión y la existencia de contraseñas predeterminadas para ejecutar un ataque de fuerza bruta exitoso. Prueba: Confirmación del equipo de ciberseguridad sobre la falta de controles y uso de contraseñas por defecto.
- **Alteración del Código:** Se introdujo código JavaScript malicioso en la fuente del sitio web para engañar a los visitantes. Prueba: Análisis del código fuente realizado por un analista senior.

- **Ejecución y Redirección:** La ejecución en sandbox confirmó el flujo del ataque: petición DNS a `yummyrecipesforme.com` -> descarga del ejecutable malicioso -> petición DNS a `greatrecipesforme.com` -> redirección a sitio con malware. Prueba: Análisis de registros de `tcpdump` en entorno aislado.
- **Descubrimiento:** El incidente fue descubierto tras recibir múltiples quejas de clientes en el servicio de atención al cliente sobre redirecciones sospechosas y degradación del rendimiento de sus sistemas. Adicionalmente, el propietario del sitio web perdió el acceso administrativo tras el cambio de contraseña por parte del atacante.

Sección 3: Recomendaciones de Seguridad (Prevención de Ataques de Fuerza Bruta)

Para mitigar el riesgo de futuros ataques de fuerza bruta contra los paneles de administración y evitar compromisos similares, se recomienda implementar urgentemente las siguientes medidas de seguridad:

Medida Principal: Limitar el número de intentos de inicio de sesión (Account Lockout Policy)

Por qué es eficaz: Los ataques de fuerza bruta se basan en probar miles de combinaciones de contraseñas de forma automatizada y rápida. Al limitar los intentos de inicio de sesión fallidos (por ejemplo, a 3 o 5 intentos) y bloquear la cuenta temporalmente (o requerir intervención del administrador para desbloquearla), se rompe la viabilidad del ataque. La automatización del atacante se detiene inmediatamente tras los primeros intentos fallidos, haciendo que el proceso de adivinar la contraseña sea computacionalmente y prácticamente imposible en un marco de tiempo razonable.

Medidas Complementarias Altamente Recomendadas:

- **Imponer Autenticación de Dos Factores (2FA / MFA):** Incluso si un atacante adivina o roba la contraseña correcta, no podrá acceder al sistema sin el segundo factor de autenticación (como un código enviado al móvil del administrador). Esta es la defensa más robusta contra credenciales comprometidas.
- **Políticas de Contraseñas Fuertes:** Forzar el cambio inmediato de contraseñas predeterminadas de fábrica y requerir combinaciones complejas (longitud mínima, uso de caracteres especiales) dificulta los ataques de diccionario y fuerza bruta simple.